

校庆纪念品认购私域微信小程序 — 测试规范

项目名称：校庆纪念品认购私域微信小程序
文档版本：v1.0
编制日期：2026-03-09
需求范围：REQ-001 ~ REQ-145

目录

- 1. 测试策略
- 2. 测试用例
 - 2.1 校友认证测试
 - 2.2 商品购买测试（国内校友+微信支付）
 - 2.3 PayPal支付测试（海外校友）
 - 2.4 定制刻字测试
 - 2.5 售后退款测试
 - 2.6 评价功能测试
 - 2.7 报表邮件测试
 - 2.8 权限控制测试
- 3. 性能测试用例
- 4. 安全测试用例
- 5. 需求对照表
- 6. 验收标准

1. 测试策略

1.1 测试层次

测试层次	说明	覆盖目标
单元测试 (Unit Test)	对 Service 层函数、工具函数进行隔离测试，使用 Mock 隔离外部依赖	代码行覆盖率 > 80%
集成测试 (Integration Test)	对 API 端点结合真实测试数据库进行验证，覆盖完整请求-响应链路	所有 API 端点 100% 覆盖
E2E测试 (End-to-End Test)	在微信开发者工具模拟器中还原完整用户操作路径，验证前后端协同	覆盖所有 P0 用户旅程
性能测试 (Performance Test)	对核心 API 进行负载测试，验证并发能力与响应时间	500 并发，P95 < 500ms
安全测试 (Security Test)	验证认证鉴权机制、注入防护、支付签名验证等安全要求	通过 OWASP Top 10 检查

1.2 测试工具

测试类型	工具	说明
单元测试	Jest (Node.js) / JUnit (Java)	根据后端技术栈选择；使用 sinon/mockito 进行 Mock
API 测试	Postman / Newman	编写 Collection，通过 Newman 在 CI 流水线中自动运行
E2E 测试	微信开发者工具自动化（miniprogram-automator）	覆盖主要用户旅程，集成至 CI
性能测试	Apache JMeter / k6	JMeter 用于场景编排；k6 用于代码化性能脚本
安全测试	OWASP ZAP	主动扫描 + 手动渗透测试辅助
代码覆盖率	Istanbul (nyc) / JaCoCo	与 CI 集成，覆盖率不达标时阻断合并

1.3 测试环境

环境名称	说明	数据库	微信支付	PayPal
开发环境	开发人员本地，独立数据库，自行维护	本地 MySQL	沙箱模式	沙箱模式
测试环境	共享测试服务器，专用测试数据库，每日清理数据	测试 MySQL	沙箱模式	沙箱模式
预发环境	与生产等配置镜像，做上线前最终验证	预发 MySQL（生产结构同步）	沙箱模式	沙箱模式
生产环境	真实用户环境，先以沙箱模式验证再切换正式	生产 MySQL	正式 / 沙箱分阶段	正式

1.4 测试优先级定义

优先级	说明	典型场景
P0（阻塞）	核心业务必须 100% 通过，否则阻断上线	登录、下单、支付、退款
P1（高）	重要功能，目标通过率 95%	刻字定制、评价、物流通知
P2（中）	增值功能，目标通过率 90%	报表、邮件、权限细节
P3（低）	优化项，可延期修复	界面细节、提示文案

2. 测试用例

2.1 校友认证测试 (REQ-001 ~ REQ-010)

测试目标：验证微信登录、校友认证申请提交与审核全流程的正确性与安全性。

用例编号	用例名称	前置条件	测试步骤
TC-001	正常微信登录流程——新用户首次登录	微信沙箱环境配置正常；测试用户未在系统注册	1. 小程序调用 <code>wx.login()</code> 获取有效 <code>code</code> 2. 调用后端接口 <code>POST /api/auth/login</code> ，传入 <code>code</code> 3. 检查响应体及数据库
TC-002	重复登录——已注册用户再次登录	测试用户已存在于数据库（ <code>status=approved</code> ）	1. 获取该用户有效微信 <code>code</code> 2. 调用 <code>POST /api/auth/login</code> 3. 比对返回 <code>userId</code> 与数据库
TC-003	无效 <code>code</code> 登录	测试环境正常	1. 调用 <code>POST /api/auth/login</code> ，传入随机字符串 <code>code="invalid"</code>
TC-004	提交校友认证——正常流程	用户已登录（有效 <code>accessToken</code> ）；用户状态为 <code>unverified</code>	1. 调用 <code>POST /api/alumni/verify</code> 2. 请求体包含： <code>name</code> （真实姓名）、 <code>studentId</code> （学号）、 <code>graduateURL</code> （毕业 URL）
TC-005	提交认证——缺少必填字段（姓名）	用户已登录，状态 <code>unverified</code>	1. 调用 <code>POST /api/alumni/verify</code> 2. 请求体中故意省略 <code>name</code> 字段
TC-006	重复提交认证——已有 <code>pending</code> 申请	用户已登录；已存在 <code>status=pending</code> 的认证申请	1. 再次调用 <code>POST /api/alumni/verify</code> ，传入完整合法参数

用例编号	用例名称	前置条件	测试步骤
TC-007	查询认证状态——审核中	用户已提交认证申请， status=pending	1. 调用 GET /api/alumni/verify/status ，携带有效 accessToken
TC-008	管理员审核通过	管理员已登录后台；存在 status=pending 的认证申请	1. 管理员调用 PUT /api/admin/alumni/verify/{id}/approve 2. 查询用户信息 3. 检查消息通知记录
TC-009	管理员审核拒绝	管理员已登录后台；存在 status=pending 的认证申请	1. 管理员调用 PUT /api/admin/alumni/verify/{id}/reject 2. 请求体包含 rejectReason （非空字符串） 3. 检查用户通知
TC-009-A	管理员拒绝——缺少拒绝原因	管理员已登录；存在 pending 申请	1. 调用拒绝接口，请求体 rejectReason 为空字符串
TC-010	未认证用户下单	用户已登录， status=unverified	1. 用户调用 POST /api/orders ，传入合法商品 SKU 与地址
TC-011	刷新 Token——正常流程	用户持有有效 refreshToken （未过期）	1. 调用 POST /api/auth/refresh ，请求体传入 refreshToken
TC-012	刷新 Token——Token 已过期	用户持有已过期的 refreshToken （可通过数据库直接置过期时间）	1. 调用 POST /api/auth/refresh ，传入过期 refreshToken

2.2 商品购买测试（国内校友 + 微信支付）(REQ-016 ~ REQ-047)

测试目标：验证商品浏览、加购、下单、微信支付、订单管理完整链路，包括库存并发控制。

用例编号	用例名称	前置条件	测试步骤	预期结果
TC-020	商品列表——正常分页查询	测试数据库已导入若干 status=active 商品；用户已登录（approved）	1. 调用 GET /api/products?page=1&pageSize=10	1. HTTP 200 2. 返回 data 数组 status=active 商品 3. 包含 total 、 page 、 分页信息 4. 已下架商品不出
TC-021	商品列表——按分类筛选	测试数据中存在多个分类商品	1. 调用 GET /api/products?categoryId=2 2. 验证响应数据	1. HTTP 200 2. 所有返回商品 categoryId=2 3. 其他分类商品不
TC-022	商品详情——正常查询	商品 id=100 存在且 status=active ； 有多个 SKU	1. 调用 GET /api/products/100	1. HTTP 200 2. 返回商品完整信, 名称、描述、图片?

用例编号	用例名称	前置条件	测试步骤	预期结果
				价格 3. 包含 SKU 列表 库存、价格) 4. 包含是否支持刻
TC-023	商品详情——商品不存在	数据库中不存在 id=99999 的商品	1. 调用 GET /api/products/99999	1. HTTP 404 2. 响应体 error.c
TC-024	商品详情——商品已下架	商品 id=101 存在，status=inactive	1. 调用 GET /api/products/101	1. HTTP 410 或 40 2. 响应体 error.c 3. 小程序端引导用户)
TC-025	加入购物车——正常流程	用户已登录 (approved)；目标 SKU 库存 >= 1	1. 调用 POST /api/cart/items，传入 skuId、quantity=1 2. 查询购物车	1. HTTP 201 2. 购物车新增一条 3. GET /api/cart 返回该商品，数量
TC-026	加入购物车——超库存数量	目标 SKU 库存为 3	1. 调用 POST /api/cart/items，传入 skuId、quantity=10	1. HTTP 400 2. 响应体 error.c 3. 错误信息提示库
TC-027	修改购物车数量——合法修改	用户购物车中存在某 SKU，当前数量为 1；该 SKU 库存为 5	1. 调用 PUT /api/cart/items/{itemId}，传入 quantity=3	1. HTTP 200 2. 购物车该条目数 3
TC-028	创建订单——正常流程	用户已登录 (approved)； 购物车含有效商品；已填写收货地址； SKU 库存充足	1. 调用 POST /api/orders，传入 cartItemIds、addressId 2. 查询数据库订单记录 3. 检查 SKU 库存	1. HTTP 201 2. 返回 orderId 及 totalAmount 3. 订单 status=pending_p 4. SKU 库存已扣减 5. 购物车对应条目
TC-029	创建订单——库存不足	目标 SKU 实际库存为 2	1. 调用 POST /api/orders，下单数量为 5	1. HTTP 400 2. 响应体 error.c 3. 库存未被扣减
TC-030	微信支付——正常流程	订单已创建，status=pending_payment； 使用微信沙箱支付	1. 调用 POST /api/payment/wechat/prepay，传入 orderId 2. 前端使用返回参数调起支付（沙箱） 3. 模拟微信回调 POST /api/payment/wechat/callback	1. 步骤1：HTTP 200 prepayId、payS 等参数 2. 步骤3：HTTP 200 3. 数据库订单 status=paid，p 有值 4. 支付记录已创建
TC-031	微信支付——回调签名验证	系统已部署回调接口	1. 直接向 POST /api/payment/wechat/callback 发送伪造请求（签名不正确） 2. 检查订单状态	1. HTTP 400 或 40 2. 订单状态未变更 3. 系统记录异常访
TC-032	订单超时自动关闭	订单 status=pending_payment； 通过数据库将 createdAt 设为 31 分钟前	1. 等待或手动触发超时任务 2. 查询订单状态 3. 检查 SKU 库存	1. 订单 status=cl 2. SKU 库存已回滚至下单 3. 超时关闭记录写
TC-033	订单详情——正常查询	用户已有订单（任意状态）	1. 调用 GET /api/orders/{orderId}	1. HTTP 200 2. 返回订单号、状 商品明细、价格、

用例编号	用例名称	前置条件	测试步骤	预期结果
				收货地址、支付信息 3. 仅返回当前用户自己
TC-034	取消订单——待支付状态	订单 status=pending_payment	1. 调用 POST /api/orders/{orderId}/cancel 2. 检查库存	1. HTTP 200 2. 订单 status=cancelled 3. SKU 库存已回滚
TC-035	取消订单——已支付状态	订单 status=paid	1. 调用 POST /api/orders/{orderId}/cancel	1. HTTP 400 2. 响应体 error.code=2002 3. 提示用户通过售后渠道 4. 订单状态未变更
TC-036	确认收货	订单 status=shipped，物流显示已送达	1. 用户调用 POST /api/orders/{orderId}/confirm-receipt 2. 检查订单状态	1. HTTP 200 2. 订单 status=completedAt 3. completedAt 时间戳记录正确 4. 售后时效计时开始
TC-037	并发下单测试——超卖防护	SKU 库存设为 5；10 个并发测试用户（均为 approved 状态）同时下单	1. 使用 JMeter/k6 模拟 10 个并发请求同时调用 POST /api/orders 2. 统计成功与失败数量 3. 查询数据库最终库存	1. 成功订单数 <= 5 2. 库存不会出现负数 3. 失败请求返回 error.code=2002 4. 总计扣减库存 = 成功订单数量之和

2.3 PayPal 支付测试（海外校友）(REQ-041 ~ REQ-048)

测试目标：验证海外校友通过 PayPal 完成支付、退款的完整链路，以及汇率换算正确性。

用例编号	用例名称	前置条件	测试步骤	预期结果
TC-050	获取汇率——正常流程	汇率数据已在 Redis 缓存或数据库中配置	1. 调用 GET /api/payment/exchange-rate?from=CNY&to=USD	1. HTTP 200 2. 返回有效汇率数值（> 0） 3. 包含汇率更新时间 4. 响应时间 < 100ms（缓存命中）
TC-051	PayPal 创建订单——正常流程	用户已登录（approved）； 订单 status=pending_payment； PayPal 沙箱配置正确	1. 调用 POST /api/payment/paypal/create，传入 orderId 2. 检查返回数据	1. HTTP 200 2. 返回 PayPal orderId 与 approved 3. 系统记录 PayPal 订单 ID 与内
TC-052	PayPal 捕获支付——正常流程	用户已在 PayPal 沙箱完成授权；持有 paypalOrderId	1. 调用 POST /api/payment/paypal/capture，传入 paypalOrderId 2. 检查内部订单状态	1. HTTP 200 2. 内部订单 status=paid 3. paidAt、paymentMethod=paypal 均已记录 4. 支付金额（USD）与 CNY 按
TC-053	PayPal 支付金额验证	商品价格 CNY 100，汇率 CNY/USD = 7.2	1. 创建 PayPal 订单 2. 检查 PayPal 侧订单金额	1. PayPal 订单金额约为 USD 13 保留2位小数） 2. 精度误差 <= USD 0.01 3. 汇率记录在支付记录中，防止
TC-054	PayPal Webhook	PayPal 沙箱 Webhook 已配置	1. 模拟 PayPal 向 POST /api/payment/paypal/webhook 发送	1. HTTP 200（必须快速响应，否 2. 内部订单 status=paid 3. 幂等处理：重复回调不重复变

用例编号	用例名称	前置条件	测试步骤	预期结果
	回调——正常处理		payment.capture.completed 事件 2. 检查内部订单状态	
TC-055	PayPal 退款流程	订单 status=paid , 售后申请已审核通过	1. 管理员触发退款, 系统调用 PayPal 退款 API 2. 检查内部订单及退款记录	1. PayPal API 返回退款成功 2. 内部订单 status=refunded 3. 退款记录包含 PayPal 退款 ID.
TC-056	汇率缓存过期——降级获取	Redis 缓存中无汇率数据 (模拟过期)	1. 清除 Redis 汇率缓存 2. 调用 GET /api/payment/exchange-rate	1. 系统从数据库获取最新配置汇率 2. 响应正常, 包含有效汇率 3. 汇率重新写入 Redis 缓存 4. 降级过程记录日志

2.4 定制刻字测试 (REQ-059 ~ REQ-065)

测试目标：验证刻字内容验证（长度、敏感词）、预览图生成与订单关联的完整流程。

用例编号	用例名称	前置条件	测试步骤	
TC-070	获取字体列表	系统已配置至少 2 种可用字体	1. 调用 GET /api/customization/fonts	1. HTTP 200 2. 返回字体列表 fontId 唯一 3. 仅返回可用字体
TC-071	刻字内容验证——正常 (20字以内)	用户已登录 (approved); 目标商品支持刻字	1. 调用 POST /api/customization/validate , 传入 content="校庆纪念, 感恩母校!" (10字)、 fontId	1. HTTP 200 2. valid 为 true 3. 字数统计正确
TC-072	刻字内容验证——超长 (> 20 字)	用户已登录 (approved)	1. 调用验证接口, 传入 21 个汉字内容	1. HTTP 400 (valid 为 false) 2. 错误信息包含 "内容超过 20 个字" 3. 不生成预览图
TC-073	刻字内容验证——含敏感词	敏感词库已配置测试敏感词 "测试敏感词"	1. 调用验证接口, 传入包含敏感词的内容	1. HTTP 400 (valid 为 false) 2. 提示信息包含敏感词 3. 敏感词匹配成功 (防止词库漏检)
TC-074	生成预览图——正常流程	内容验证通过 (TC-071 场景)	1. 调用 POST /api/customization/preview , 传入合法 content、 fontId、 productId 2. 检查返回 URL	1. HTTP 200 2. 返回有效预览图 URL 3. URL 可访问 4. 预览图清晰
TC-075	含刻字内容创建订单	刻字内容已验证通过, 持有 customizationId	1. 调用 POST /api/orders , 订单行中包含 customizationId 2. 查询订单详情	1. HTTP 201 2. order 创建成功 customizationId 正确 3. 刻字内容正确 (非全部商品支持)
TC-076	管理员查看刻字内容	含刻字的订单已创建	1. 管理员调用 GET /api/admin/orders/{orderId} 2. 检查刻字信息	1. HTTP 200 2. 订单详情包含刻字预览图 URL 3. 管理员可查看刻字内容 (用于售后)
TC-077	不支持刻字的商品提交刻字	商品 id=200 , supportCustomization=false	1. 调用 POST /api/customization/validate , 传入 productId=200	1. HTTP 400 2. 提示该商品不支持刻字

用例编号	用例名称	前置条件	测试步骤	
				3. 下单时亦返回错

2.5 售后退款测试 (REQ-054 ~ REQ-058, REQ-113 ~ REQ-120)

测试目标：验证售后申请提交、时效控制、管理员审核与退款执行的完整流程。

用例编号	用例名称	前置条件	测试步骤	预期结果
TC-080	申请退款——已签收状态（退款）	订单 status=completed， 签收时间在 30 天内	1. 调用 POST /api/after-sale，传入 orderId、type=refund、reason（文字）、images（可选）	1. HTTP 201 2. 售后申请 status=pending 3. 返回 afterSaleId
TC-081	申请退货退款——已发货未签收	订单 status=shipped	1. 调用 POST /api/after-sale，传入 type=return_refund	1. HTTP 201 2. 售后申请创建成功，type=return_refund 3. 提示用户等待管理员提供退货地址
TC-082	重复申请售后	已存在 status=pending 的售后申请	1. 再次调用 POST /api/after-sale，传入同一 orderId	1. HTTP 409 2. 提示"已有处理中的售后申请，请勿重复提交" 3. 不创建新记录
TC-083	售后超期——签收超 30 天	通过数据库将 completedAt 设为 31 天前	1. 调用 POST /api/after-sale，传入该订单 orderId	1. HTTP 400 2. 响应体 error.code=50001 3. 提示"售后申请已超过有效期"
TC-084	管理员审核通过——触发微信退款	售后申请 status=pending； 原支付方式为微信支付	1. 管理员调用 PUT /api/admin/after-sale/{id}/approve 2. 检查微信退款记录 3. 检查订单状态	1. HTTP 200 2. 系统调用微信退款 API 成功 3. 订单 status=refunded 4. 退款记录包含微信退款单号 5. 用户收到退款成功通知
TC-085	管理员审核通过——触发 PayPal 退款	售后申请 status=pending； 原支付方式为 PayPal	1. 管理员调用审核通过接口 2. 检查 PayPal 退款状态	1. HTTP 200 2. 系统调用 PayPal 退款 API 成功 3. 订单 status=refunded 4. 退款金额（USD）按原支付金额
TC-086	管理员审核拒绝	售后申请 status=pending	1. 管理员调用 PUT /api/admin/after-sale/{id}/reject，传入非空 rejectReason	1. HTTP 200 2. 售后申请 status=rejected 拒绝原因保存 3. 订单状态不变 4. 用户收到含拒绝原因的微信通知
TC-087	退款金额验证——不超过实付金额	订单实付金额 CNY 200	1. 管理员尝试触发退款金额 CNY 201 2. 检查是否被拒绝	1. 系统拒绝退款金额超出实付金额 2. 返回参数校验错误 3. 实际退款金额不超过 CNY 200

2.6 评价功能测试 (REQ-066 ~ REQ-072)

测试目标：验证评价提交限制（订单状态、重复评价）、图片上传、匿名功能与信息隐私保护。

用例编号	用例名称	前置条件	测试步骤	
TC-090	提交评价——已完成订单	订单 status=completed； 该商品未评价	1. 调用 POST /api/reviews，传入 orderId、productId、rating=5、content="非常满意"	1. 成功提交评价

用例编号	用例名称	前置条件	测试步骤
TC-091	提交评价——订单未完成	订单 status=shipped（未确认收货）	1. 调用 POST /api/reviews，传入该 orderId
TC-092	重复评价——同订单同商品	已对该订单中的商品提交过评价	1. 再次调用 POST /api/reviews，传入相同 orderId 和 productId
TC-093	上传评价图片——正常（≤9张，单张 ≤5MB）	用户已登录； 测试图片文件准备好	1. 调用图片上传接口，上传 3 张图片（各 2MB） 2. 提交评价时附带图片 URL
TC-093-A	上传评价图片——超张数（10 张）	用户已登录	1. 尝试上传 10 张图片或提交含 10 个 URL 的评价
TC-093-B	上传评价图片——单张超 5MB	用户已登录；准备 6MB 图片文件	1. 上传 6MB 图片文件
TC-094	匿名评价——设置匿名	评价数据准备好	1. 调用评价接口，传入 anonymous=true 2. 调用商品评价列表接口
TC-095	商品评价列表——分页与排序	商品已有多条评价	1. 调用 GET /api/products/{productId}/reviews?page=1&pageSize=10&sort=latest
TC-096	评价隐私——刻字内容不暴露	含刻字商品的订单已评价	1. 调用商品评价列表接口（非管理员身份） 2. 检查评价内容

2.7 报表邮件测试 (REQ-128 ~ REQ-138)

测试目标：验证数据统计准确性、报表生成、定时任务触发与邮件发送可靠性。

用例编号	用例名称	前置条件	测试步骤	预期结果	价
TC-100	手动生成日报	测试数据库中有当日 N 笔已支付订单，总金额已知	1. 管理员调用 POST /api/admin/reports/daily， 传入 date=today 2. 下载报表内容	1. HTTP 200，报表生成成功 2. 销售订单数与数据库 SELECT COUNT(*) 吻合 3. 销售总额与 SELECT SUM(paidAmount) 吻合 4. 报表包含：商品维度、 分类维度销售明细	P

用例编号	用例名称	前置条件	测试步骤	预期结果	优先级
TC-101	手动发送报表邮件	SMTP 配置正确 (测试邮箱)；报表已生成	1. 管理员调用 POST /api/admin/reports/send , 传入报表 ID 与收件人列表 2. 检查测试邮箱	1. HTTP 200 2. 收件人收到邮件 3. 邮件标题包含日期 4. 附件为 Excel 或 PDF 格式， 可正常打开 5. 附件数据与 TC-100 一致	P
TC-102	配置定时邮件——日报	定时任务服务正常运行	1. 配置日报定时任务，发送时间设为 5 分钟后 2. 等待触发 3. 检查邮件与数据库 last_sent_at	1. 定时准时触发（误差 < 1 分钟） 2. 收件人收到报表邮件 3. 数据库 report_schedules.last_sent_at 更新为当前时间	P
TC-103	配置定时邮件——周报	定时任务服务正常运行	1. 配置周报定时任务 2. 手动触发周报生成 3. 检查周报时间范围	1. 周报时间范围为上周一至周日 2. 数据汇总正确 3. report_schedules 记录更新	P
TC-104	报表数据准确性验证	数据库中有明确的测试数据 (10 笔订单，已知金额)	1. 生成报表 2. 将报表数据与 SQL 直接查询结果对比	1. 报表中所有数值与 SQL 查询结果完全一致 2. 包含退款订单的处理逻辑正确 (退款金额从销售额扣除)	P
TC-105	邮件发送失败重试	模拟 SMTP 服务不可用 (配置错误 Host)	1. 触发报表发送 2. 等待重试 3. 检查日志与数据库	1. 系统重试 3 次（间隔可配置） 2. 3 次失败后记录 status=failed 到发送日志 3. 不无限重试，停止并告警（日志/ 通知）	P
TC-106	报表收件人管理	管理员已登录	1. 调用添加收件人接口 POST /api/admin/reports/recipients 2. 调用删除收件人接口 3. 触发发送，验证实际收件人	1. 添加：HTTP 201， 收件人列表更新 2. 删除：HTTP 200， 该收件人不再收到邮件 3. 删除后发送的报表仅发给剩余收件人	P

2.8 权限控制测试 (REQ-079 ~ REQ-085)

测试目标：验证后台管理端的登录认证、RBAC 权限控制与 JWT 时效管理。

用例编号	用例名称	前置条件	测试步骤	预期结果
TC-110	管理员登录——正常流程	管理员账号已在后台创建， status=active	1. 调用 POST /api/admin/auth/login , 传入正确 username 、 password	1. HTTP 200 2. 返回 accessToken 3. 返回管理员角色信息
TC-111	管理员登录——错误密码	管理员账号存在	1. 调用登录接口，传入错误密码 2. 重复调用 5 次 3. 检查账号状态	1. 每次返回 HTTP 401 2. 记录失败次数 3. 达到阈值后账号锁定
TC-112	无权限访问——越级操作	运营管理员（ role=operator ）已登录； 超级管理员接口已部署	1. 使用运营管理员 token 调用超级管理员专属接口（如 DELETE /api/admin/users/{id} ）	1. HTTP 403 2. 响应体 error.cc 3. 错误信息明确说明 4. 操作未执行，审计
TC-113	JWT 过期—— 管理端接口访问	管理员持有已过期的 accessToken （通过数据库修改过期时间）	1. 使用过期 token 调用任意管理接口	1. HTTP 401 2. 响应体 error.cc 3. 提示 Token 已过期

用例编号	用例名称	前置条件	测试步骤	
TC-114	角色分配权限——即时生效	角色 R002 当前无 product:edit 权限	1. 超级管理员为 R002 分配 product:edit 权限 2. 持有 R002 的管理员立即调用商品编辑接口	1. 分配操作：HTTP 2. 权限分配后该管理员（无需重新登录） 3. 权限变更记录审计
TC-115	撤销权限——即时生效	角色 R002 当前有 product:edit 权限	1. 超级管理员撤销 R002 的 product:edit 权限 2. 持有 R002 的管理员调用商品编辑接口	1. 撤销操作：HTTP 2. 撤销后该接口返回 3. 权限撤销记录审计
TC-116	小程序用户访问管理接口	小程序用户已登录（有效 accessToken， userType=miniprogram）	1. 使用小程序 token 调用 GET /api/admin/orders（管理端接口）	1. HTTP 403 2. 提示无权访问管理 3. 请求被记录至安全

3. 性能测试用例

测试工具：Apache JMeter 5.x 或 k6 v0.45+

测试环境：测试服务器（与生产配置一致），数据库预热（至少 10,000 条商品、1,000 条订单）

用例编号	用例名称	测试场景	测试参数	验收标准	关联需求
TC-P001	商品列表接口压测	模拟 500 个并发用户同时请求商品列表，持续 5 分钟	并发用户：500 Ramp-up：30 秒 持续时间：5 分钟 请求间隔：1 秒	1. 平均响应时间 < 500ms 2. P95 响应时间 < 800ms 3. 错误率 < 0.1% 4. TPS > 100	REQ-016
TC-P002	创建订单接口压测	模拟 100 个并发用户同时创建订单，验证无超卖	并发用户：100 Ramp-up：10 秒 目标 SKU 库存：1000 持续时间：2 分钟	1. 成功率 > 99% 2. 无库存超卖（最终库存 >= 0） 3. 平均响应时间 < 1000ms 4. 数据库事务无死锁日志	REQ-031, REQ-032
TC-P003	支付回调接口压测	模拟高频微信支付回调（实际支付峰值的 3 倍）	并发回调：50 次/秒 持续时间：1 分钟	1. 所有回调正确处理 2. 幂等处理：重复回调不重复变更状态 3. 回调响应时间 < 200ms（否则微信会重试）	REQ-042, REQ-043
TC-P004	小程序首页加载性能	在弱网环境（模拟 4G：带宽 20Mbps，延迟 100ms）下测试首页加载	网络：4G 模拟 测试设备：主流 iOS/Android 机型 测试工具：微信开发者工具网络模拟	1. 首屏关键内容渲染 < 3 秒 2. 完全加载 < 5 秒 3. 关键图片懒加载，不阻塞首屏	REQ-011
TC-P005	PayPal 汇率接口压测	验证 Redis 缓存命中下汇率接口的并发能力	并发用户：200 持续时间：2 分钟	1. 平均响应时间 < 100ms（缓存命中） 2. 缓存未命中时 < 500ms 3. 错误率 < 0.01%	REQ-045
TC-P006	系统整体吞吐量测试	混合场景：浏览商品（70%）+ 创建订单（20%）+ 查询订单（10%）	总并发：500 持续时间：10 分钟	1. 系统 TPS > 200 2. 平均响应时间 < 500ms 3. CPU 使用率 < 70% 4. 内存无持续增长（无内存泄漏）	全模块

4. 安全测试用例

测试工具：OWASP ZAP、Burp Suite（手工辅助）、自定义脚本
参考标准：OWASP Top 10 (2021)

用例编号	用例名称	测试目标	测试方法	预期结果
TC-S001	SQL 注入测试	验证商品搜索、订单查询接口防注入能力	1. 在 keyword 参数注入： ' OR '1'='1、 '； DROP TABLE orders;-- 2. 在 orderId 路径参数注入 SQL 片段 3. 使用 OWASP ZAP 自动扫描	1. 所有注入请求返回参数 2. 数据库执行计划失败 3. ORM 框架使用参数无拼接 SQL
TC-S002	XSS 攻击测试	验证商品评价、刻字内容输入的 XSS 防护	1. 在评价 content 字段提交 <script>alert(1)</script> 2. 在刻字 content 字段提交 HTML 标签 3. 检查存储内容与渲染结果	1. 存储时对 HTML 特殊字符转义或拒绝 2. 前端渲染时不执行 3. 返回原始输入时已转义
TC-S003	越权访问——水平越权	验证用户 A 无法访问用户 B 的订单、评价、售后申请	1. 用户 A 登录，获取 token 2. 用用户 A 的 token 请求 GET /api/orders/{userB_orderId} 3. 尝试取消用户 B 的订单	1. HTTP 403 或 404 2. 响应不包含用户 B 的任何数据 3. 用户 B 的订单状态不变
TC-S004	支付金额篡改测试	验证服务端以订单金额为准，不信任前端传入金额	1. 正常发起支付请求 2. 使用 Burp Suite 拦截，将金额参数从 ¥100 篡改为 ¥0.01 3. 检查实际支付金额	1. 服务端以数据库订单不使用前端传入金额 2. 微信支付预下单金额与数据库订单金额一致 3. 伪造金额请求返回错误
TC-S005	微信回调伪造测试	验证微信支付回调签名验证不可绕过	1. 构造一个 orderId 有效但签名错误的回调请求，直接 POST 到回调接口 2. 构造签名正确但金额不一致的回调 3. 检查订单状态	1. 签名验证失败：回调失败，订单状态不变 2. 金额不一致：请求记录安全日志 3. 所有伪造尝试写入安全日志
TC-S006	PayPal Webhook 伪造测试	验证 PayPal Webhook 签名验证不可绕过	1. 向 POST /api/payment/paypal/webhook 发送伪造 Webhook（不含正确签名头） 2. 使用修改后的 PayPal Webhook 签名	1. HTTP 400，拒绝 2. 内部订单状态不变 3. 伪造请求记录安全日志
TC-S007	敏感数据传输安全	验证 API 通信全程使用 HTTPS	1. 使用 HTTP 访问 API 端点 2. 抓包检查 Headers	1. HTTP 请求强制重定向到 HTTPS 2. 响应包含 Strict-Transport-Security: max-age=31536000 3. 无 Cookie 或 Token 明文传输
TC-S008	暴力破解防护	验证管理员登录接口的暴力破解防护	1. 使用脚本在 60 秒内向登录接口发送 20 次错误密码请求	1. 达到失败阈值（如 5 次）后账号临时锁定 2. 返回 HTTP 429 Too Many Requests 3. 锁定期间正确密码也无法登录 4. 失败记录写入安全日志

5. 需求对照表（全量覆盖 REQ-001 到 REQ-145）

需求编号	需求名称	对应测试用例	测试重点
认证模块（小程序）			
REQ-001	微信登录（wx.login code 换取 token）	TC-001, TC-002, TC-003	code 有效性验证、新用户创建、token 返回
REQ-002	Token 管理（accessToken/refreshToken 机制）	TC-001, TC-011, TC-012, TC-113	Token 签发、刷新、过期处理
REQ-003	校友认证申请提交	TC-004, TC-005, TC-006	必填项校验、重复申请检测
REQ-004	认证申请状态查询	TC-007	状态返回正确性
REQ-005	认证状态展示（小程序端）	TC-007	用户界面状态同步
REQ-006	管理员认证审核（通过/拒绝）	TC-008, TC-009, TC-009-A	审核流程、状态变更
REQ-007	审核通过后用户状态变更	TC-008	用户 status=approved 更新
REQ-008	审核结果通知用户（微信消息）	TC-008, TC-009	通知触发、内容正确性
REQ-009	拒绝原因必填与存储	TC-009, TC-009-A	拒绝原因非空校验
REQ-010	未认证用户禁止下单	TC-010	鉴权拦截、错误码 1003
首页模块（小程序）			
REQ-011	首页加载性能	TC-P004	弱网环境下 < 3 秒
REQ-012	首页商品分类展示	TC-021	分类数据正确性
REQ-013	首页轮播图/Banner 展示	(UI 测试, E2E 验证可见性)	Banner 配置正确展示
REQ-014	首页热门商品展示	TC-020	热门商品列表返回
REQ-015	首页公告/活动信息展示	(E2E 验证内容展示)	公告内容正确渲染
商品模块（小程序）			
REQ-016	商品列表接口（分页）	TC-020, TC-021, TC-P001, TC-S001	分页正确、下架商品过滤
REQ-017	商品分类筛选	TC-021	分类过滤正确性
REQ-018	商品详情（含 SKU 信息）	TC-022, TC-023, TC-024	商品完整信息、SKU 列表
REQ-019	商品搜索关键词	TC-S001	搜索功能与注入防护
REQ-020	商品图片展示	TC-022	图片 URL 有效性
REQ-021	SKU 规格选择	TC-022, TC-028	SKU 选择与库存绑定
REQ-022	库存实时展示	TC-022, TC-029	库存数量正确反映
REQ-023	商品评分展示	TC-090, TC-095	评分聚合计算正确
REQ-024	刻字支持标识展示	TC-022, TC-077	支持刻字标识正确
REQ-025	商品收藏功能	(E2E 验证收藏列表)	收藏/取消逻辑
购物车模块（小程序）			
REQ-026	加入购物车	TC-025, TC-026	正常加购、超库存拒绝
REQ-027	购物车库存检查	TC-026, TC-037	实时库存校验
REQ-028	修改购物车数量	TC-027	数量合法性与库存校验
REQ-029	删除购物车商品	(E2E 验证删除)	购物车条目删除

需求编号	需求名称	对应测试用例	测试重点
REQ-030	购物车商品选中/全选	(E2E 验证 UI 交互)	选中状态管理
订单模块 (小程序)			
REQ-031	创建订单 (从购物车)	TC-028, TC-029, TC-P002	订单创建、库存扣减
REQ-032	订单库存扣减与并发控制	TC-028, TC-029, TC-037	悲观/乐观锁防超卖
REQ-033	订单详情查询	TC-033, TC-S003	订单信息完整性、越权防护
REQ-034	订单列表查询 (分页)	(E2E 验证订单历史列表)	订单分页与状态筛选
REQ-035	订单超时自动关闭 (30分钟)	TC-032	超时关闭、库存回滚
REQ-036	取消订单 (待支付状态)	TC-034, TC-035	状态机限制、库存回滚
REQ-037	确认收货	TC-036	状态变更、售后时效启动
REQ-038	订单状态流转 (状态机)	TC-028, TC-030, TC-034, TC-035, TC-036	所有合法/非法状态转换
REQ-039	收货地址管理	(E2E 验证地址增删改查)	地址 CRUD 操作
REQ-040	发票信息 (如有)	(E2E 验证发票申请)	发票信息填写与关联
支付模块 (小程序)			
REQ-041	微信支付预下单	TC-030, TC-S004	支付参数生成、金额不可篡改
REQ-042	微信支付回调处理	TC-031, TC-S005, TC-P003	签名验证、幂等处理
REQ-043	支付签名安全性	TC-031, TC-S005	伪造签名被拒绝
REQ-044	PayPal 支付流程	TC-051, TC-052, TC-054, TC-S006	PayPal 完整支付链路
REQ-045	汇率获取与缓存	TC-050, TC-056, TC-P005	汇率正确性、缓存降级
REQ-046	PayPal 金额换算	TC-053	CNY/USD 精确换算
REQ-047	支付记录创建	TC-030, TC-052	支付记录完整性
REQ-048	PayPal 退款	TC-055, TC-085	PayPal 退款 API 调用
物流模块 (小程序)			
REQ-049	物流单号绑定 (管理端录入)	(管理端 E2E 测试)	物流单号与订单绑定
REQ-050	物流信息查询 (第三方 API)	(集成测试, Mock 物流 API)	物流信息正确展示
REQ-051	物流状态更新通知	(集成测试, 消息通知)	状态变更触发通知
REQ-052	多包裹支持	(E2E 验证多物流单)	同一订单多物流单
REQ-053	物流异常处理	(集成测试, Mock 异常)	查询失败降级处理
售后模块 (小程序)			
REQ-054	售后申请提交 (退款/退货退款)	TC-080, TC-081	申请类型、状态创建
REQ-055	售后申请图片上传	TC-080	图片附件上传与关联
REQ-056	重复申请售后防护	TC-082	重复提交拒绝
REQ-057	售后时效限制 (30天)	TC-083	超期拒绝、错误码 5002
REQ-058	售后申请状态查询	TC-080, TC-086	状态正确展示
定制刻字模块 (小程序)			
REQ-059	字体列表获取	TC-070, TC-077	字体列表返回、不支持刻字商品限制

需求编号	需求名称	对应测试用例	测试重点
REQ-060	刻字内容输入	TC-071	内容正常提交
REQ-061	刻字字数限制（20字）	TC-071, TC-072	超长内容拒绝
REQ-062	敏感词过滤	TC-073, TC-S002	敏感词检测与拒绝
REQ-063	刻字预览图生成	TC-074	预览图 URL 有效性
REQ-064	刻字信息关联到订单	TC-075	customizationId 正确关联
REQ-065	管理端查看刻字要求	TC-076	管理员查看刻字详情
评价模块（小程序）			
REQ-066	评价提交（订单完成后）	TC-090, TC-091	订单状态限制
REQ-067	评分（1-5星）	TC-090	评分范围校验
REQ-068	重复评价防护	TC-092	同订单同商品不重复
REQ-069	评价图片上传（最多9张，单张≤5MB）	TC-093, TC-093-A, TC-093-B	图片数量与大小限制
REQ-070	匿名评价	TC-094	匿名展示与真实ID保存
REQ-071	评价列表（分页+排序）	TC-095	按时间倒序分页
REQ-072	刻字内容隐私保护	TC-096	刻字内容不对外暴露
消息通知模块（小程序）			
REQ-073	认证结果通知	TC-008, TC-009	通过/拒绝通知触发
REQ-074	订单状态变更通知	TC-030, TC-032	支付成功、超时关闭通知
REQ-075	发货通知	（集成测试，物流绑定后触发）	发货消息推送
REQ-076	售后处理结果通知	TC-084, TC-086	审核通过/拒绝通知
REQ-077	微信服务消息模板管理	（管理端 E2E 测试）	模板配置与预览
REQ-078	通知发送失败重试	（集成测试，Mock 微信 API 失败）	失败重试与日志记录
权限管理（后台）			
REQ-079	管理员账号登录	TC-110, TC-111, TC-S008	登录流程、暴力破解防护
REQ-080	管理端 Token 管理	TC-113	JWT 过期处理
REQ-081	RBAC 角色权限控制	TC-112, TC-114, TC-115, TC-116	角色权限隔离
REQ-082	权限不足访问拦截	TC-112	错误码 9004
REQ-083	角色权限动态分配与撤销	TC-114, TC-115	即时生效
REQ-084	小程序用户禁止访问管理端	TC-116	用户类型隔离
REQ-085	操作审计日志	TC-112, TC-114, TC-115	关键操作记录
校友管理（后台）			
REQ-086	校友申请列表查询	（管理端 E2E 测试）	申请列表分页展示
REQ-087	校友申请详情查看	TC-008, TC-009	申请材料展示
REQ-088	批量审核申请	（管理端 E2E 测试）	批量通过/拒绝
REQ-089	校友信息修改	（管理端 E2E 测试）	校友资料编辑
REQ-090	校友账号禁用/启用	（管理端 E2E 测试）	禁用后无法登录
REQ-091	校友数据导出	（管理端 E2E 测试）	Excel 导出格式验证

需求编号	需求名称	对应测试用例	测试重点
REQ-092	校友搜索（姓名/学号）	（管理端 E2E 测试）	搜索准确性
商品管理（后台）			
REQ-093	商品创建	（管理端 E2E 测试）	商品信息完整性校验
REQ-094	商品编辑	TC-114, TC-115（权限）+（E2E）	编辑后商品详情更新
REQ-095	商品上架/下架	TC-024	下架商品用户端不可见
REQ-096	SKU 管理（规格/库存/价格）	TC-022, TC-028	SKU 数据正确关联
REQ-097	商品图片上传管理	（管理端 E2E 测试）	图片上传与展示
REQ-098	商品分类管理	TC-021	分类创建与商品归属
REQ-099	库存预警设置	（管理端 E2E 测试）	低库存告警触发
REQ-100	刻字支持配置	TC-077	刻字开关影响小程序端
REQ-101	商品批量操作	（管理端 E2E 测试）	批量上下架
REQ-102	商品数据导入（Excel）	（管理端集成测试）	导入格式验证与数据正确性
订单管理（后台）			
REQ-103	订单列表查询（多维度筛选）	（管理端 E2E 测试）	状态、时间、金额筛选
REQ-104	订单详情查看（含刻字、支付信息）	TC-076	刻字信息可见性
REQ-105	订单手动关闭	（管理端 E2E 测试）	关闭后库存回滚
REQ-106	订单备注/标记	（管理端 E2E 测试）	备注保存与展示
REQ-107	发货操作（录入物流单号）	REQ-049 对应测试	物流单号与订单绑定
REQ-108	订单数据导出（Excel）	（管理端集成测试）	导出数据与数据库一致
REQ-109	退款操作（手动触发）	TC-084, TC-085, TC-087	退款金额校验与 API 调用
REQ-110	订单搜索（订单号/用户/商品）	（管理端 E2E 测试）	搜索结果准确性
REQ-111	批量发货处理	（管理端 E2E 测试）	批量录入物流信息
REQ-112	订单超时预警	TC-032	即将超时订单提醒
物流售后管理（后台）			
REQ-113	售后申请列表管理	TC-080, TC-086	申请列表展示与筛选
REQ-114	售后审核通过——微信退款	TC-084	退款 API 调用成功
REQ-115	售后审核通过——PayPal 退款	TC-085	PayPal 退款 API 调用成功
REQ-116	售后审核拒绝（填写原因）	TC-086	拒绝原因必填校验
REQ-117	退款金额验证	TC-087	不超过实付金额
REQ-118	物流异常处理标记	（管理端 E2E 测试）	异常标记与处理流程
REQ-119	退货地址配置	（管理端 E2E 测试）	退货地址管理
REQ-120	售后数据统计	（管理端 E2E 测试）+ TC-100	售后率等统计数据
支付管理（后台）			
REQ-121	支付记录查询	（管理端 E2E 测试）	支付记录完整性
REQ-122	退款记录查询	TC-084, TC-085	退款记录完整性
REQ-123	微信支付配置管理	（管理端 E2E 测试）	配置保存与生效
REQ-124	PayPal 配置管理	TC-051, TC-052	沙箱/正式环境切换

需求编号	需求名称	对应测试用例	测试重点
REQ-125	汇率配置管理	TC-056	汇率更新与缓存刷新
REQ-126	对账功能（支付平台 vs 数据库）	（管理端集成测试）	金额差异检测
REQ-127	支付异常记录与告警	TC-031, TC-S005	异常记录与告警触发
数据统计（后台）			
REQ-128	销售总额统计	TC-100, TC-104	统计准确性验证
REQ-129	日/周/月销售报表	TC-100, TC-102, TC-103	时间维度报表正确
REQ-130	商品维度销售统计	TC-100, TC-104	按商品分类汇总
REQ-131	订单状态分布统计	TC-104	各状态订单数量准确
REQ-132	用户增长统计（新注册/认证）	TC-104	用户数据统计准确
REQ-133	退款率统计	TC-100, TC-104	退款金额与数量
REQ-134	报表邮件发送（手动）	TC-101	邮件格式与附件正确
REQ-135	定时邮件发送配置	TC-102, TC-103	定时触发与记录
REQ-136	邮件发送失败重试	TC-105	3次重试与失败记录
REQ-137	报表收件人管理	TC-106	收件人增删管理
REQ-138	数据可视化（图表）	（E2E 验证图表展示）	图表数据与统计一致
系统设置（后台）			
REQ-139	基础系统参数配置	（管理端 E2E 测试）	参数保存与生效
REQ-140	敏感词库管理	TC-073	敏感词增删与过滤生效
REQ-141	公告/Banner 内容管理	REQ-013, REQ-015 对应 E2E	内容发布与前端展示
REQ-142	售后时效配置（默认30天）	TC-083	配置变更影响时效判断
REQ-143	订单超时时间配置（默认30分钟）	TC-032	配置变更影响超时逻辑
REQ-144	SMTP 邮件服务配置	TC-101, TC-105	SMTP 配置保存与连通性测试
REQ-145	系统日志查询	TC-S003, TC-S005	安全日志与操作日志查询

6. 验收标准

6.1 功能验收

优先级	通过率要求	说明
P0（阻塞）	100%	所有 P0 测试用例必须全部通过，任何 P0 失败均阻断上线
P1（高）	≥ 95%	允许最多 5% 的 P1 用例存在已知问题，但需记录修复计划
P2（中）	≥ 90%	允许最多 10% 的 P2 用例存在已知问题
P3（低）	≥ 80%	优化类问题，可在后续版本迭代中修复

关键业务零缺陷要求：

- 下单流程（REQ-031 ~ REQ-038）：零 P0 缺陷
- 微信支付流程（REQ-041 ~ REQ-043）：零 P0 缺陷
- PayPal 支付流程（REQ-044 ~ REQ-048）：零 P0 缺陷
- 退款流程（REQ-114 ~ REQ-117）：零 P0 缺陷

Bug 严重度分类：

严重度	定义	修复时限
Blocker	阻断核心业务流程，无 workaround	24 小时内修复
Critical	功能严重缺陷，有 workaround	48 小时内修复
Major	功能缺陷，影响用户体验	当前迭代内修复
Minor	轻微缺陷或 UI 问题	下个迭代修复

6.2 性能验收

指标	目标值	测试场景
核心 API 响应时间（P95）	< 500ms	500 并发用户，持续 5 分钟
核心 API 响应时间（P99）	< 1000ms	500 并发用户
最大并发用户数	≥ 500	混合场景压测
支付成功率	> 99.5%	100 并发下单支付
系统可用性（SLA）	> 99.9%	7×24 小时统计周期
小程序首屏渲染时间	< 3 秒	4G 网络模拟
数据库连接池利用率	< 80%	峰值场景
服务器 CPU 使用率	< 70%	峰值场景

6.3 安全验收

安全要求	验收标准
OWASP Top 10	全部 10 项通过扫描，无高危漏洞
支付签名验证	微信支付与 PayPal 签名验证覆盖率 100%
SQL 注入防护	所有 API 入口经过 OWASP ZAP 扫描无漏洞
XSS 防护	所有用户输入经过净化，前端渲染使用安全 API
越权访问	水平越权（用户间）和垂直越权（权限层级）均不可绕过
敏感数据保护	用户 openid、支付密钥等不在日志和响应中明文暴露
HTTPS 强制	所有接口仅允许 HTTPS，HTTP 自动重定向
暴力破解防护	登录失败 5 次锁定，管理端增加 CAPTCHA

6.4 用户体验验收

体验指标	验收标准
小程序首屏加载时间	< 3 秒（4G 网络）
关键操作路径步骤数	不超过 5 步（从选商品到完成支付）
微信版本兼容性	支持 iOS 和 Android 微信最新正式版本
错误提示友好性	所有错误响应提供用户可理解的中文提示

体验指标	验收标准
弱网优雅降级	3G 网络下核心功能可用，展示加载状态
操作响应反馈	所有按钮操作 < 300ms 有视觉反馈（loading 状态）

6.5 上线前 Checklist

检查项	负责人	完成标志
所有 P0 测试用例通过	测试负责人	测试报告盖章
性能压测报告达标	性能测试工程师	压测报告归档
OWASP ZAP 扫描无高危	安全工程师	安全报告归档
微信支付沙箱完整验证	后端工程师	支付测试记录
PayPal 沙箱完整验证	后端工程师	支付测试记录
数据库备份与回滚方案验证	DBA	备份恢复演练记录
灰度发布方案确认	发布负责人	发布计划文档
监控告警配置完成	运维工程师	告警触发验证记录

文档版本历史

版本	日期	修改人	修改内容
v1.0	2026-03-09	—	初版创建，覆盖 REQ-001 ~ REQ-145